

Protecting Users with “Protected Users”

Jake Hildreth
Senior Security Consultant
Trimarc

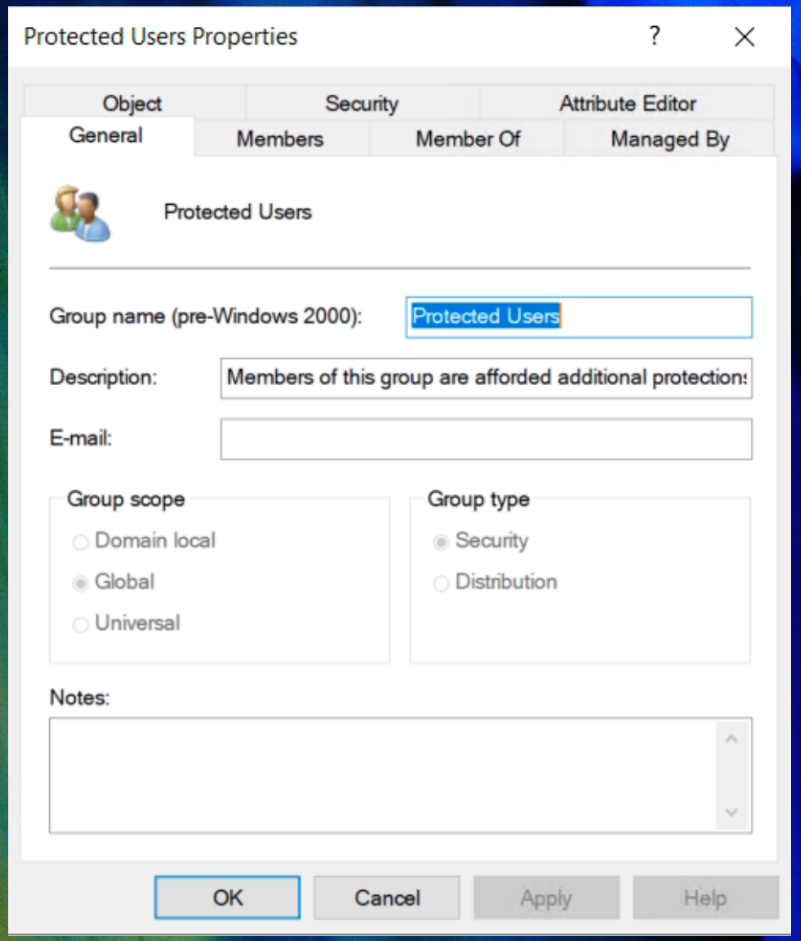
Who?

- Recovering Sysadmin
- Trimarc Active Directory Security Assessment service lead
- Husband
- Dad
- Blue Team 4 Lyfe



What?

- Special Group in Active Directory (AD)
- Adds non-configurable protections to members of the group
- Created in Server 2012 R2 domain functional level
- 2012 R2 and Win 8.1 supported by default
- Support was backported to Windows 7, Server 2008 R2, and Server 2012
- Must assign PDCe FSMO role to 2012 R2 DC



Why this talk?

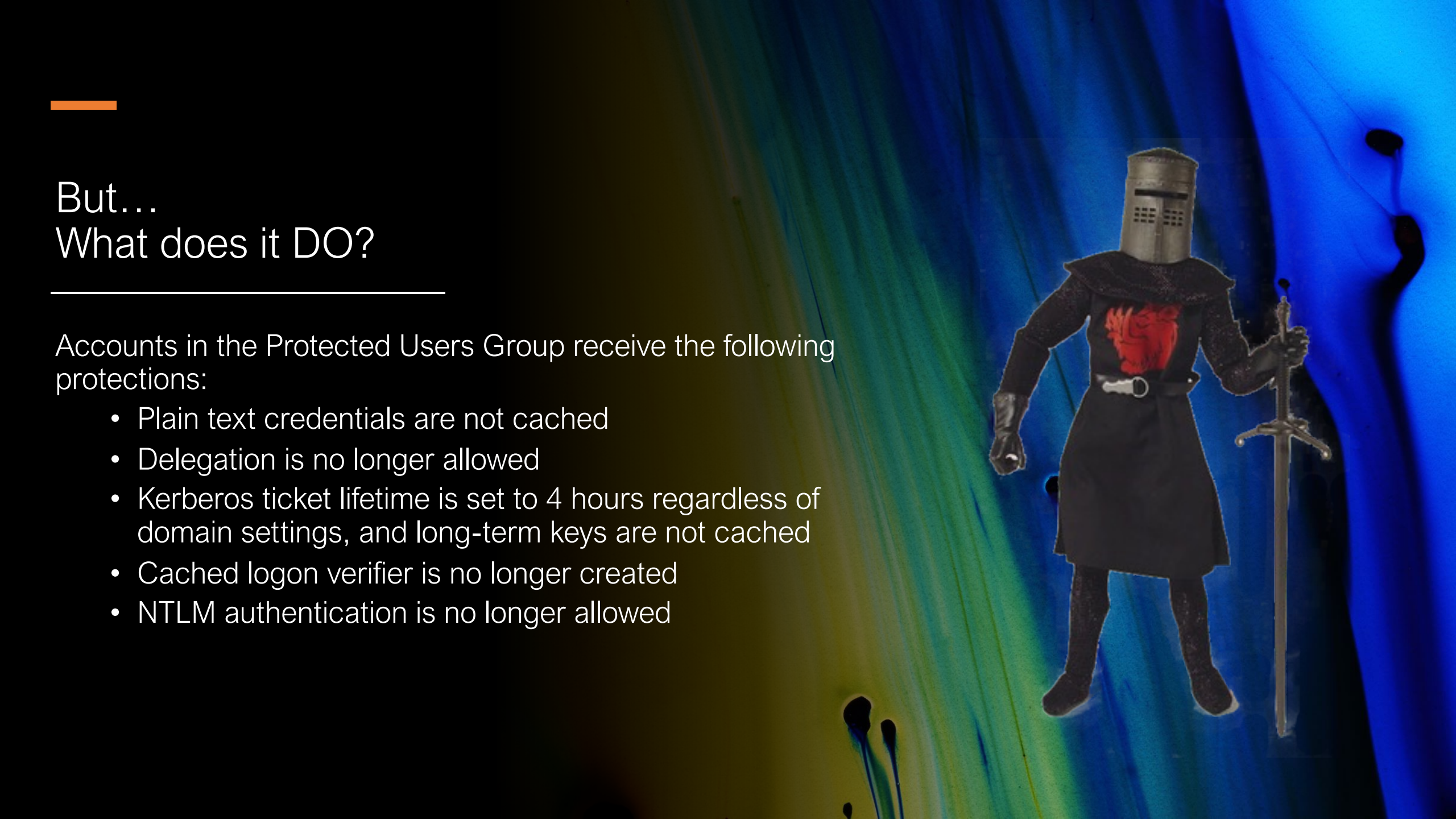
NO ONE USES THIS GROUP



But…
What does it DO?

Accounts in the Protected Users Group receive the following protections:

- Plain text credentials are not cached
- Delegation is no longer allowed
- Kerberos ticket lifetime is set to 4 hours regardless of domain settings, and long-term keys are not cached
- Cached logon verifier is no longer created
- NTLM authentication is no longer allowed



Why do those protections matter?

- Prevents fallout from than less-than-ideal admin account behaviors:
  - No account tiering or tiering not enforced
  - AD admins as Service Accounts
  - Open virtual infrastructure sessions
- Greatly increases the difficulty of delegation attacks
- Greatly increases the difficulty of Pass-the-Hash attacks



How?

- Before testing:
  - Ensure all your DCs are running fully-patched Server 2008 or higher
  - Change any AD admin passwords that were set before the DFL was upgraded to Server 2008
- Start with one AD admin user & test thoroughly for at least a month
- Add another few and test for a month
- Rinse and repeat, but…



Limitations?

- Using IP addresses will generally fail
- DNS round robin can fail
- No non-Windows support
- Offline sign-in no longer allowed
- Some applications require delegation for proper function
- Some applications **still** do not fully support Kerberos



Thanks!



Questions?